

Progetto S9 - L5

Studente: Domenico Vitale

Oggetto: Analisi traffico di rete – File PCAP

Strumento utilizzato: Wireshark

Executive Summary

L'analisi della cattura di rete ha evidenziato un'attività anomala riconducibile a una fase di ricognizione interna mediante scansione TCP (TCP SYN scan).

L'host 192.168.200.100 ha effettuato numerosi tentativi di connessione verso porte differenti dell'host 192.168.200.150, senza stabilire comunicazioni applicative reali.

Dalla cattura emerge inoltre che l'host 192.168.200.150 si identifica come "METASPLOITABLE", sistema comunemente utilizzato in ambienti di laboratorio per simulare macchine vulnerabili. Questo elemento rafforza l'ipotesi di uno scenario di penetration testing controllato.

Non sono stati rilevati exploit né trasferimenti di payload, ma esclusivamente attività di enumerazione dei servizi.

Contesto della Cattura

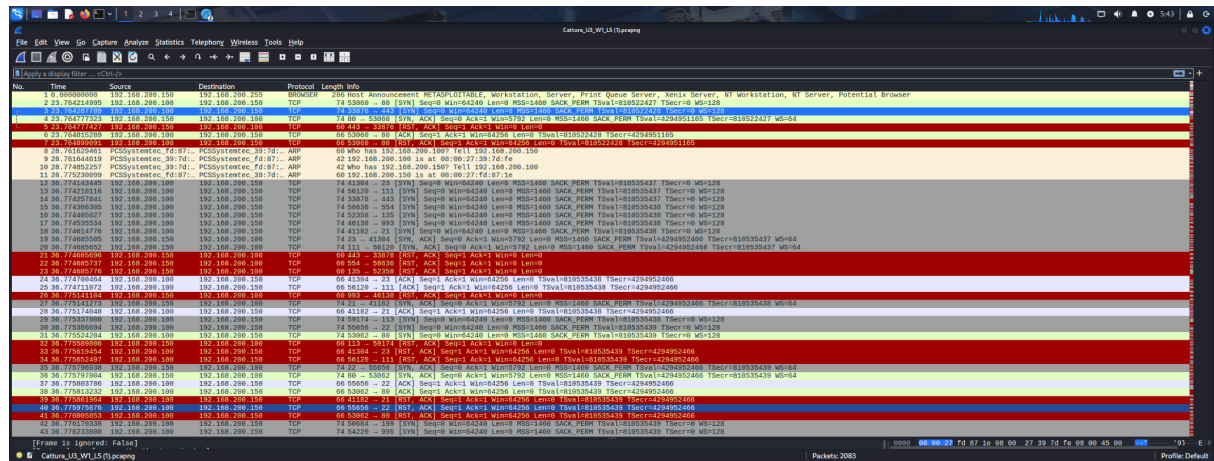
Nella prima riga del traffico si osserva:

- Annuncio NetBIOS (Protocol "Browser")
- Nome host: METASPLOITABLE
- IP: 192.168.200.150

Questo indica che l'host target è una macchina volutamente vulnerabile, tipicamente utilizzata in ambienti di test per esercitazioni di sicurezza informatica.

Pertanto, l'attività rilevata appare coerente con uno scenario simulato di attacco interno finalizzato alla ricognizione.

Fig. 1.



Analisi Tecnica

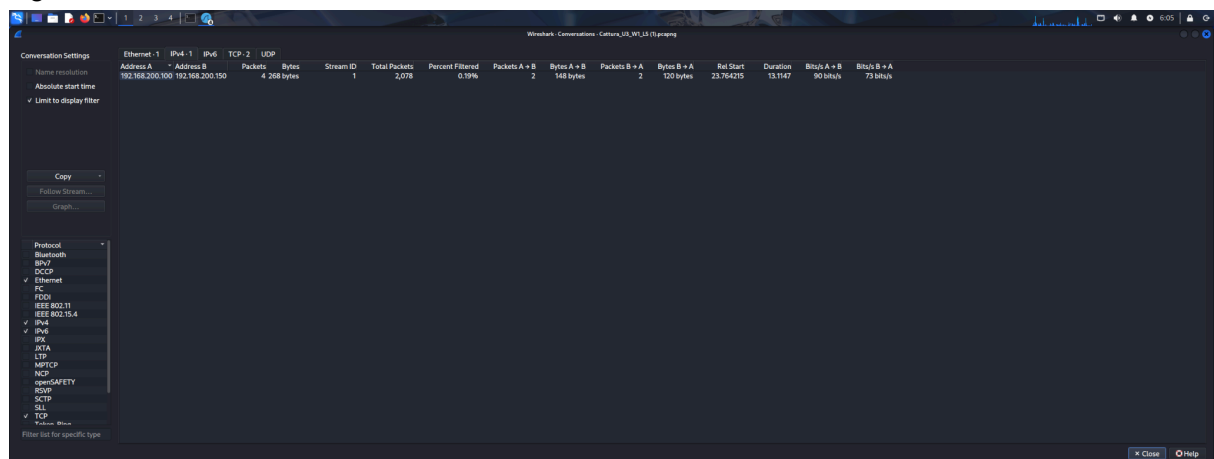
Identificazione degli Host Coinvolti

Dalla sezione Statistics → Conversations emerge che:

- 192.168.200.100 avvia connessioni verso numerose porte
- 192.168.200.150 risponde ai tentativi di connessione

L'host 192.168.200.100 risulta quindi essere l'origine dell'attività di scansione.

Fig.2



Indicatori di Compromissione (IOC)

Sono stati identificati i seguenti indicatori:

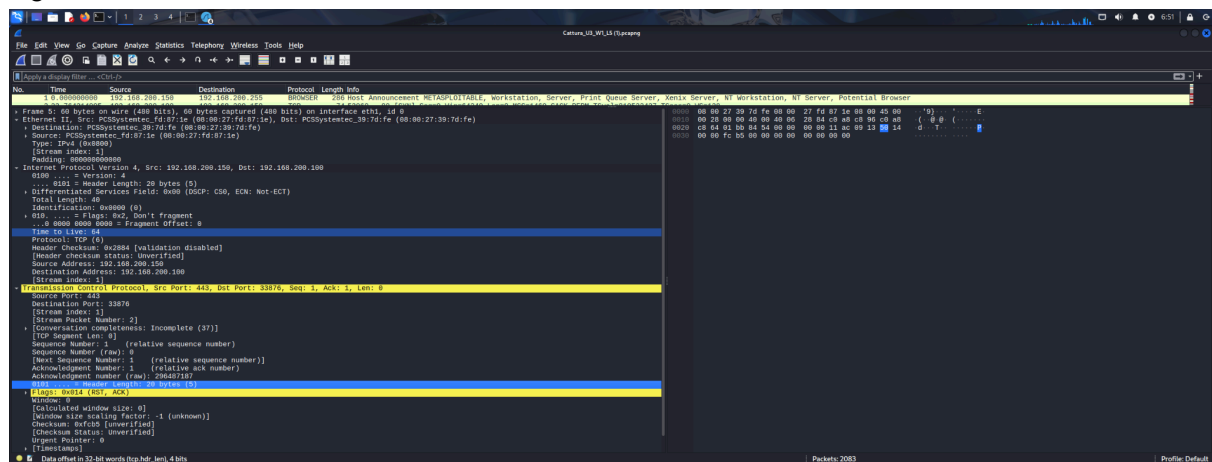
1. Elevato numero di pacchetti TCP con flag SYN verso porte differenti
2. Risposte RST/ACK su porte chiuse
3. Risposta SYN/ACK su porta 443 (porta aperta)
4. Chiusura immediata della connessione tramite RST
5. Assenza totale di traffico applicativo (TCP Len = 0)
6. Pattern ripetitivo e automatizzato dei pacchetti

Il comportamento è tipico di una **TCP SYN scan (half-open scan)**.

Analisi dei Livelli del Pacchetto

L'analisi è stata approfondita esaminando i dettagli nel pannello inferiore di Wireshark.

Fig.3



Frame:

- Lunghezza costante dei pacchetti (~60–74 byte)
- Intervalli temporali ravvicinati
- Nessuna frammentazione

Il traffico appare automatizzato e ripetitivo.

Ethernet II:

- MAC address coerenti con comunicazione interna
- Nessuna evidenza di spoofing
- Traffico ARP normale e funzionale alla risoluzione IP/MAC

Non sono emerse evidenze di ARP poisoning.

Internet Protocol (IPv4):

- IP sorgente costante: 192.168.200.100
- IP destinazione: 192.168.200.150
- TTL coerente e stabile (Time To Live)
- Nessuna anomalia nei campi IP

Questo conferma l'origine interna dell'attività.

Transmission Control Protocol (TCP):

L'analisi TCP evidenzia:

- Numerosi flag SYN verso porte differenti (80, 443, 23, 111, 25, 445, ecc.)
- RST/ACK su porte chiuse
- SYN/ACK su porta 443 (porta aperta)
- Successivo RST per chiusura immediata
- TCP Len = 0 (assenza di payload applicativo)
- Parametri costanti (Window Size, MSS, Timestamp)

Questo schema è coerente con una scansione TCP finalizzata all'identificazione dei servizi attivi.

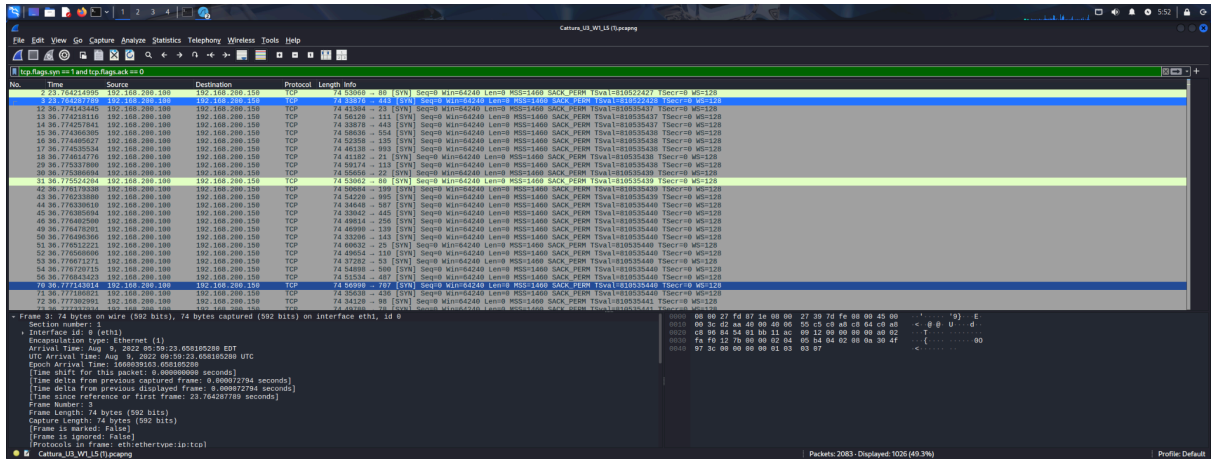
Filtri Utilizzati:

Durante l'analisi sono stati applicati i seguenti filtri:

Individuazione tentativi iniziali (SYN):

tcp.flags.syn == 1 and tcp.flags.ack == 0

Permette di visualizzare i tentativi di connessione verso porte multiple.

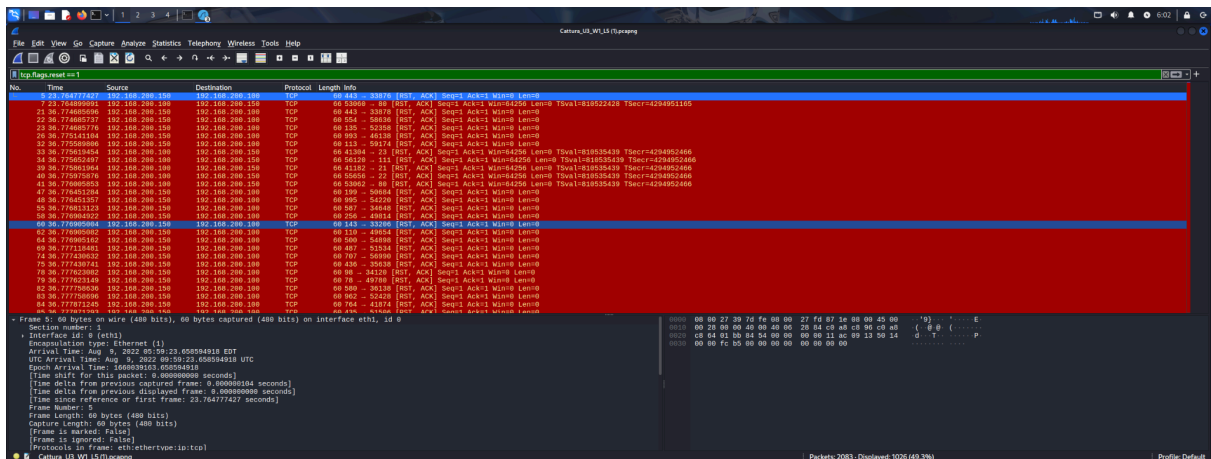


Individuazione reset:

tcp.flags.reset == 1

Consente di isolare le risposte di porte chiuse o le chiusure immediate.

Fig.5

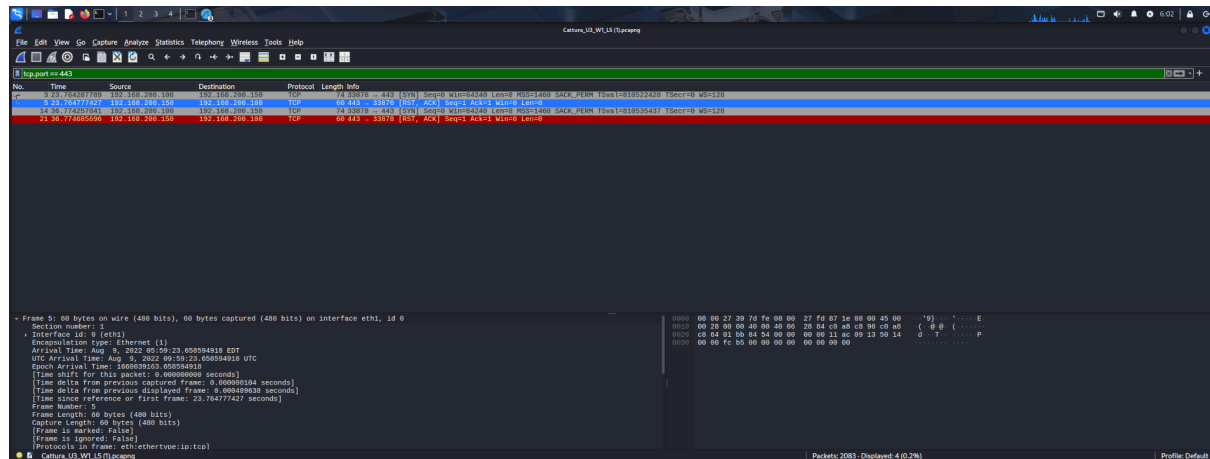


Analisi porta 443:

tcp.port == 443

Utilizzato per analizzare il 3-way handshake e la successiva chiusura della connessione.

Fig.6



Ipotesi sul Vettore di Attacco

L'attività osservata è riconducibile a una fase di ricognizione interna.

L'host 192.168.200.100 effettua una scansione delle porte TCP sull'host 192.168.200.150 (Metasploitable) con l'obiettivo di:

- Identificare servizi attivi
- Valutare potenziali vulnerabilità
- Preparare un eventuale attacco successivo

Il comportamento è compatibile con l'uso di strumenti automatizzati di scanning, come Nmap.

Raccomandazioni e Mitigazione

Azioni Immediate:

- Isolamento dell'host 192.168.200.100
- Analisi forense del sistema
- Verifica dei log della macchina target

Azioni Preventive:

- Implementazione IDS/IPS per traffico interno
- Segmentazione della rete (VLAN)
- Hardening dei servizi esposti
- Monitoraggio e alert su pattern di scansione
- Applicazione del principio di least privilege

Conclusione

L'analisi del file PCAP evidenzia un'attività di scansione TCP interna verso una macchina vulnerabile di laboratorio (Metasploitable).

Non sono stati rilevati exploit né compromissioni attive, ma esclusivamente una fase di reconnaissance. L'identificazione tempestiva di tale comportamento è fondamentale per prevenire eventuali fasi successive di attacco.